

Compliance Build Spec

Requirements for the development team — and its coding AI.

FDA medical-device line · FTC claim rules · biometric privacy (BIPA + state laws)
data security · children's data · Apple App Store review · build checklists

GOAL: ship a cosmetic / general-wellness app. NOT a medical device. NOT a diagnosis. NOT a lawsuit.

WHAT'S INSIDE

1	The one rule everything depends on	Stay in the cosmetic / wellness lane
2	FDA — not a medical device	What makes a face-scan app 'regulated'
3	Claims & language (FTC + FDA)	The approved-vs-banned wording library
4	Biometric privacy — the big one	BIPA + Texas + Washington + 20 states
5	Data privacy & security	Breach rule, ad-SDK trap, user rights
6	Children's data (COPPA)	Why we gate to 18+
7	Apple App Store review	Every guideline a face/health app hits
8	Build checklist — screens & flows	The implementable requirement list
9	Copy-paste blocks for the coder	Strings, consent copy, disclaimers
10	Pre-launch legal checklist	What to do before you ship

Product: TrueTone (working codename) · Build jurisdiction: Illinois, USA **This is engineering guidance, not legal advice.**
Date: June 2026 · Status: v1 draft for developer hand-off **A licensed attorney must review before launch.**

How to use this document

This is a build specification, written so it can be read by both a human developer and an AI coding assistant. It uses **MUST** / **MUST NOT** / **SHOULD** in the RFC sense: **MUST** = hard requirement, treat as a launch blocker; **MUST NOT** = prohibited, will create legal exposure; **SHOULD** = strong recommendation. Where exact strings are given (permission text, disclaimers, consent copy), use them close to verbatim and adjust only with counsel.

The whole document flows from one strategic decision the founders have already made: **TrueTone is a cosmetic / general-wellness product, not a medical device, and it never diagnoses anything**. Every rule below is downstream of holding that line. If a feature request would break it, escalate to the founders before building.

IMPORTANT — WHAT THIS IS AND ISN'T

This document is engineering/compliance guidance prepared from public regulatory sources current to mid-2026. It is **not legal advice** and creates no attorney-client relationship. Laws change and apply to specific facts. Before public launch the company **MUST** have this reviewed by (a) a US privacy/biometric attorney licensed in Illinois and (b) ideally an FDA regulatory advisor. Budget for it; it is cheaper than one BIPA class action.

PART 1

The one rule everything depends on

Stay in the cosmetic / general-wellness lane. Describe appearance; never diagnose disease.

US regulators decide what your app *is* based on what it *claims to do* — its “intended use.” The same camera and model can be a harmless beauty tool or a regulated medical device; the words in the UI and model outputs are what move it across the line. TrueTone wins by being unmistakably the former. Three commitments, baked into the product:

- **We describe how skin LOOKS** (dry-looking, visible texture, the appearance of blemishes, uneven-looking tone). We never state or imply a medical diagnosis.
- **We recommend over-the-counter cosmetic care and habits.** We never claim to treat, cure, prevent, or “fix” a disease, and never claim to change the skin's underlying structure.
- **When something looks medically concerning, we redirect, we don't diagnose:** a neutral “consider seeing a board-certified dermatologist” — never “this looks like [condition].”

Hold these three and the FDA, FTC, and Apple medical-app problems largely disappear. Break any one and the app can be reclassified as a medical device and/or hit with a deceptive-claims action. Everything in Parts 2–3 is just this rule, in detail.

PART 2

FDA — staying out of medical-device territory

Software “intended for maintaining or encouraging a healthy lifestyle” and **unrelated to the diagnosis, cure, mitigation, prevention, or treatment of a disease** is excluded from the FDA ‘device’ definition (FD&C; Act §520(o)(1)(B); reaffirmed in FDA’s January 2026 General Wellness guidance). Software that uses the camera as a **diagnostic tool**, or performs patient-specific analysis to **diagnose or recommend treatment for disease**, IS a regulated device. The dividing line is intended use and claims — not the technology.

What this means for the build

DO (compliant)

- Score cosmetic attributes: hydration look, oiliness, visible texture, pores, the appearance of dark spots / redness / fine lines / dark circles.
- Classify cosmetic skin TYPE (dry / oily / combination / sensitive-feeling).
- Recommend OTC product categories, ingredients, and habits.
- Use hedged, appearance-based language ('looks', 'appears', 'the appearance of').
- Show a dermatologist-referral nudge for anything unusual.

DON'T (triggers risk)

- Output a disease diagnosis ('you have acne / rosacea / eczema / melasma / skin cancer').
- Detect, screen, triage, or assess risk of ANY disease or lesion (no mole/cancer checking — ever).
- Claim to treat, cure, prevent, heal, or 'clear up' a condition.
- Claim to change skin structure/function ('boosts collagen', 'repairs the barrier', 'shrinks pores').
- Imply clinical/medical-grade accuracy or that it replaces a doctor.

HARD LINE FOR ENGINEERING & MODEL PROMPTS

The analysis model **MUST** be constrained (via its system prompt, output schema, and a post-filter) so it can only return cosmetic, appearance-based descriptors from an approved vocabulary. Disease names **MUST** be blocklisted from all user-facing output. “Cancer”, “melanoma”, and mole/lesion assessment **MUST** be hard-refused with the dermatologist referral, regardless of how the user phrases the request.

PART 3

Claims & language compliance (FTC + FDA)

Two regimes govern the words in the app. **The FTC** (Section 5) requires every objective claim to be truthful, non-misleading, and **substantiated** before it's made — this includes health/beauty claims AND 'AI' claims (the FTC is actively pursuing 'AI-washing'). **The FDA's cosmetic-vs-drug line** (FD&C; Act) means any claim to treat disease or affect the skin's structure/function turns a recommendation into an unapproved 'drug' claim. The app must satisfy both at once.

3.1 The language library (constrain model output to this)

This table is the single most useful artifact for the coding assistant: it defines the wording the app may and may not generate. Treat the right column as a blocklist.

USE — cosmetic / substantiated	NEVER — drug / disease / unsubstantiated
"Your skin looks dehydrated."	"You have dehydration / a barrier disorder."
"The appearance of blemishes / breakouts."	"Your acne" / "we'll treat your acne."
"Improves the look of fine lines."	"Reduces wrinkles" / "boosts collagen."
"Helps skin look more even-toned."	"Treats melasma / hyperpigmentation disorder."
"Soothes the look of redness."	"Treats / cures rosacea."
"A gentle exfoliant may help."	"This will clear / heal your condition."
"Consider seeing a dermatologist."	"This looks like [disease] / could be cancer."
"Many users with similar skin like..."	"Clinically proven to fix..." (without proof).

3.2 Claim-substantiation rules (FTC)

- Every objective claim **MUST** be substantiated *before* publication. If we say "92% saw smoother-looking skin," we **MUST** hold the data. Avoid invented stats entirely in v0.
- **AI claims are claims.** Don't say "dermatologist-level," "clinically accurate," or "medically validated" unless literally true and documented. Prefer "AI-powered skin-appearance analysis."
- **Accuracy & fairness:** if we publish any accuracy figure (including our skin-tone-equity claim), we **MUST** be able to back it with our own validation data. Don't market the equity promise before the validation exists.
- **Endorsements/testimonials** **MUST** be genuine, typical, and disclose material connections (per FTC endorsement rules). No fake reviews.

3.3 Required standing disclaimers (ship in-app)

These **MUST** appear: at onboarding, on every results screen (at least via an info affordance), and in the Terms. Exact strings in Part 9.

- **Not-medical disclaimer** — the app provides cosmetic/wellness information, is not a medical device, does not diagnose or treat, and is not a substitute for a professional.
- **See-a-doctor prompt** — urging users to consult a dermatologist for any skin concern, new/changing spot, or medical question.

- **AI-limitations note** — results are AI-generated estimates of appearance and may be imperfect; lighting and image quality affect them.

PART 4

Biometric privacy — the highest-risk area

A scan that maps facial geometry from a photo or video is **biometric data**. This is the single most dangerous area for a face-scanning app, and TrueTone is being built in **Illinois** — home of BIPA, the only US biometric law that lets individuals sue directly, with no proof of harm required. Get the consent architecture right on day one; it cannot be safely retrofitted.

4.1 Illinois BIPA — the five obligations (740 ILCS 14/15)

BIPA applies to face-geometry scans (mere photos are excluded, but geometric analysis of a face is in scope — assume we are covered). Section 15 imposes five duties; each maps to a concrete build requirement:

BIPA §	The duty	Build requirement
15(b)	Informed written consent BEFORE collection.	Standalone consent screen shown before the first scan, stating what biometric data is collected, the specific purpose, and how long it's kept; user gives an explicit opt-in (electronic signature/affirmative tap is OK). Log consent (timestamp, version).
15(a)	Public written retention & destruction policy.	Publish a policy stating the retention schedule and that biometric data is destroyed when its purpose is met OR within 3 years of the user's last interaction, whichever is first. Implement the auto-deletion job to enforce it.
15(c)	No sale or profit from biometric data.	Never sell, lease, trade, or otherwise profit from face data. Hard architectural rule.
15(d)	No disclosure without consent.	Don't share biometric data with any third party without separate consent (or legal compulsion). Affects vendor/SDK choices — see Part 5.
15(e)	Reasonable security; protect like (or better than) other sensitive data.	Encrypt in transit and at rest; access controls; deletion verified. Document the security program.

Penalties (why this is a launch blocker): statutory damages of \$1,000 per person (negligent) or \$5,000 per person (reckless/intentional) — plus attorneys' fees, with a 5-year limitations period. A 2024 amendment limits recovery to per-person rather than per-scan, but class-wide exposure is still enormous (Facebook settled a BIPA face case for \$650M).

4.2 The other state laws (build to the strictest, apply everywhere)

- **Texas (CUBI):** notice + consent before capturing biometrics for a commercial purpose. Enforced by the AG only (\$25k/violation) — but Texas won a \$1.4B settlement from Meta. Destroy within a reasonable time, no later than 1 year after the purpose ends.
- **Washington (My Health My Data Act):** very broad — 'consumer health data' includes biometric data and even imagery *from which a template can be extracted* (a skin selfie likely qualifies). Requires consent, a **separate** standalone consumer-health-data privacy policy, signed authorization to sell, and has a **private right of action**. Treat as a second BIPA.
- **~20 comprehensive state privacy laws** (California CCPA/CPRA, Virginia, Colorado, Connecticut, Texas, Oregon, etc.) classify biometric + health data as **sensitive**, generally requiring opt-in consent (opt-out + limits in California) and granting access/delete/correct rights.

- **GDPR (if any EU users):** face/biometric + health data are 'special category' (Art. 9) needing explicit consent.
Recommendation: geo-restrict v0 to the US to defer GDPR until we're ready.

THE SIMPLIFYING STRATEGY

Don't build 50 compliance modes. Build ONE flow to the strictest common denominator (BIPA + Washington MHMDA): explicit opt-in consent before capture, data minimization, no sale, no third-party sharing of biometric/health data, a published retention schedule with enforced auto-deletion, and in-app access/delete. Apply it to every user regardless of state. That single flow satisfies essentially every US jurisdiction at once.

PART 5

Data privacy & security

Beyond biometrics specifically, face/skin data is sensitive health-adjacent data. Two FTC-driven rules and a set of engineering practices apply.

5.1 The ad/analytics-SDK trap (this is how similar apps got fined)

The FTC's **Health Breach Notification Rule** (amended, effective July 29, 2024) now covers health and wellness apps not under HIPAA, and defines a reportable 'breach' to include **unauthorized disclosure** — e.g., leaking user health data to advertising/analytics platforms via tracking SDKs or pixels. The FTC has hit GoodRx, BetterHelp, Premom, and Flo on exactly this. Concrete rules:

- **MUST NOT** embed third-party advertising or analytics SDKs that can access face images, skin data, scan results, or health inferences. No Meta Pixel / ad-network SDKs touching this data.
- **MUST NOT** share or sell skin/face/health data to data brokers or ad platforms (also a BIPA §15(c) violation).
- If any analytics is used, it **MUST** be privacy-preserving, exclude health/biometric data, and be disclosed; honor App Tracking Transparency.
- **MUST** honor your own privacy promises exactly — the FTC treats a broken privacy promise as a deceptive practice under Section 5.
- **MUST** have a breach-response plan (notify users, the FTC, and in some cases media) ready before launch.

5.2 Engineering practices (MUST/SHOULD)

- **Data minimization (MUST):** collect only what the feature needs. Strongly prefer deriving cosmetic scores and then **discarding the raw face image**.
- **On-device or ephemeral processing (SHOULD, strongly):** if the raw image never leaves the device, or is deleted immediately after analysis, BIPA/MHMDA/HBNR exposure drops dramatically. This is both the safest and most marketable architecture.
- **Encryption (MUST):** TLS in transit; encryption at rest for any stored image/template/result.
- **User rights (MUST):** in-app access to their data and one-tap delete-everything (ties to Apple 5.1.1(v) and state privacy laws). Deletion **MUST** purge biometric data from all systems, including backups on a defined cycle.
- **Retention enforcement (MUST):** automated deletion job implementing the published schedule.
- **Vendor diligence (MUST):** any model/API vendor that processes face data **MUST** be under a contract barring their reuse of the data, and disclosed in the privacy policy.

PART 6

Children's data (COPPA) — gate to 18+

Face data from minors is the highest-liability data there is. The FTC's amended **COPPA Rule** (in force 2025–26) now expressly classifies **biometric identifiers, including facial patterns, as 'personal information'**, and requires **verifiable parental consent** before collecting it from a child under 13, plus a written security and data-retention program. Separately, BIPA applies regardless of age (and minors can't validly consent themselves), and many state laws give extra protection to teens under 18.

Recommended approach for v0

- **Restrict the app to users 18+ (MUST for v0).** Cleanest way to avoid COPPA's parental-consent machinery and minors'-biometric risk entirely. Revisit a teen experience later, with counsel, if ever.
- **Implement a real age gate (MUST):** a neutral date-of-birth entry (not a checkbox), enforced before any scan; block under-18s; don't store under-18 face data.
- **Don't design or market to minors (MUST):** avoid child-directed styling, characters, or placements that would make TrueTone a 'child-directed' or 'mixed-audience' service under COPPA.
- If the company ever chooses to serve under-18s, it MUST first build verifiable parental consent, minor-specific data minimization, and a legal review — a significant project, not a toggle.

ONE-LINE RULE FOR THE CODER

No face scan is captured, processed, or stored for anyone who has not passed an 18+ age gate. Treat age verification as a precondition to the camera screen.

PART 7

Apple App Store review compliance

Apple's App Review will scrutinize a face-scanning, skin-related app closely. Hitting these guidelines is required to get approved AND to stay approved through updates. Each maps to a build task.

Guideline	What it requires of TrueTone
1.4.1 Medical apps	Medical apps that diagnose/treat or give inaccurate info get heightened scrutiny and can be rejected if accuracy can't be validated. Mitigation: present as cosmetic/wellness, not medical ; clearly communicate the methodology and that outputs are appearance estimates. Don't claim diagnosis.
5.1.1(i) Privacy policy + consent	Apps using the Camera, Photos, or ARKit/facial-depth APIs MUST have a privacy policy and obtain consent for data collection. Provide a complete, linked privacy policy and the consent flow (Part 4).
5.1.1(v) Account deletion	If users can create an account, the app MUST let them initiate full account + data deletion from within the app (deactivation is insufficient). Build the in-app delete flow.
5.1.1(ix) Regulated / sensitive data	Apps handling sensitive data / regulated services may be required to submit from an Organization Apple Developer account (not Individual) and demonstrate legitimacy. Action: enroll the company (LLC) as an Organization.
5.1.2 Permission & transparency	Don't access/transmit personal data without permission and a clear explanation of use. Provide purpose strings and just-in-time prompts.
5.1.3 Health data handling	Health/fitness/medical-context data MUST NOT be used for advertising, marketing, or data-mining, or shared with third parties for those purposes. Reinforces the Part 5 SDK rules.
App Privacy labels + ATT	Declare ALL data collected (including via any SDK) in App Privacy 'nutrition labels'; 2026 review demands more detail. If anything tracks across apps, implement App Tracking Transparency. Best path: collect minimally so labels are clean.
AI transparency (2026)	2026 review expects apps to explain AI/automated features and when content is AI-generated. Add a plain-language 'how the AI works / its limits' explainer.

Face-data specifics

- **Prefer the standard camera (a selfie photo)** over the TrueDepth/ARKit face-mesh APIs. If ARKit/TrueDepth face data is used, Apple's terms restrict it: such data **MUST NOT** be used for advertising or identity, **MUST NOT** leave the device for those purposes, and must stay tied to the feature. Using a plain photo keeps us clear of those extra restrictions.
- Provide clear, specific permission purpose strings (exact text in Part 9).
- Make the privacy policy and the biometric consent both reachable before the first scan.

PART 8

Build checklist — required screens & flows

Consolidated, implementable requirements. Each line is a MUST unless marked. This is the section to turn into tickets.

Onboarding & gating (before any camera access)

- Age gate (neutral DOB entry); block under-18; no face data collected for under-18.
- Biometric consent screen (standalone), shown before first scan; explicit opt-in; consent logged with timestamp + policy version.
- Links to Privacy Policy and Terms reachable before the scan.
- Camera/Photos permission prompt with purpose strings (Part 9).

Scan & results

- Guided capture; process to cosmetic scores; SHOULD discard raw image after analysis (or store encrypted only with consent).
- Results use only approved cosmetic vocabulary (Part 3 library); disease terms blocklisted in output.
- Standing disclaimer accessible on results (not-medical + see-a-doctor + AI-limits).
- Dermatologist-referral nudge path for unusual results; never a diagnosis.

Privacy, data rights & security

- In-app 'Your Data' screen: view what's stored; one-tap delete-everything (purges biometric data + backups on a defined cycle).
- In-app account deletion (Apple 5.1.1(v)).
- Automated retention/auto-deletion job per the published schedule (BIPA: purpose-met or 3 yrs).
- Encryption in transit + at rest; no health/biometric data in any ad/analytics SDK.
- No selling/sharing of biometric or health data to third parties.

Account & store setup (non-code, but required)

- Enroll the company as an Organization in the Apple Developer Program (5.1.1(ix)).
- Publish: (1) main Privacy Policy, (2) standalone Biometric Data Policy w/ retention schedule, (3) Washington-style consumer-health-data policy if serving WA, (4) Terms with disclaimers.
- Complete App Privacy 'nutrition labels' truthfully (include any SDK data).
- Geo-restrict v0 to the US (defer GDPR) [SHOULD].

PART 9

Copy-paste blocks for the coding assistant

Drop-in starting text. Have counsel review before launch, but these are written to be compliant-by-default and used near-verbatim.

iOS permission purpose strings (Info.plist)

```
NSCameraUsageDescription =
"TrueTone uses your camera to take a photo of your skin so the app can
estimate its visible appearance and suggest a cosmetic skincare routine.
Your image is processed for analysis and is not sold or shared."

NSPhotoLibraryUsageDescription =
"TrueTone accesses a photo you choose so it can estimate your skin's
visible appearance. Photos are used only for analysis, never sold."
```

Biometric consent screen copy (shown before first scan)

Before we scan your skin

To analyze your skin's appearance, TrueTone captures a photo of your face and measures visible features of your skin (a 'biometric identifier' under laws like Illinois' BIPA).

- Purpose: to estimate your skin's appearance and suggest a cosmetic routine.
- We do NOT sell, lease, or trade this data, ever.
- We delete it when its purpose is met or within 3 years of your last use, whichever comes first - and anytime you tap Delete My Data.

[] I have read the Biometric Data Policy and consent to TrueTone collecting and storing my biometric data as described.

[Decline] [I Consent]

Standing disclaimer (results screen + Terms)

TrueTone is a cosmetic and general-wellness tool. It is not a medical device, does not diagnose, treat, or prevent any disease or condition, and is not a substitute for professional medical advice. Results are AI-generated estimates of your skin's appearance and may be affected by lighting and image quality. For any skin concern - or any new, changing, or unusual spot - please consult a board-certified dermatologist.

Privacy-policy must-include checklist (for whoever drafts it):

- What is collected (face image, derived skin metrics, account info) and the specific purpose.

- That facial data is a biometric identifier; the retention schedule and destruction timeline.
- Explicit statement that biometric/health data is never sold, leased, traded, or shared for ads.
- Third-party processors used (e.g., the analysis vendor) and that they may not reuse the data.
- User rights and how to exercise them: access, delete, withdraw consent.
- Security measures; breach-notification commitment; contact for privacy requests.
- A separate standalone Biometric Data Policy (BIPA) and, if serving WA, a consumer-health-data policy.

PART 10

Pre-launch legal checklist

Do not treat 'ship it' as the finish line. Before public launch:

- **Retain an Illinois-licensed privacy/biometric attorney** to review the consent flow, biometric policy, retention schedule, and privacy policy. This is the highest-ROI legal spend you'll make.
- **Have the claims/UI copy reviewed** against FDA cosmetic-vs-drug and FTC substantiation rules (an FDA/advertising regulatory advisor, or the same firm).
- **Form the company (LLC/Corp)** and enroll it as an Apple Organization; route data contracts through the entity, not a personal name.
- **Sign data-processing agreements** with every vendor that touches face data, barring reuse.
- **Stand up the breach-response plan** (HBNR timelines) and the security program documentation.
- **Decide geographic scope** (US-only for v0 recommended) and configure the age gate + geo-gating.
- **Keep records:** consent logs, your skin-tone-fairness validation data (substantiates the equity claim), and policy versions.

THE 30-SECOND SUMMARY FOR THE DEV TEAM

Cosmetic language only, never a diagnosis. Explicit opt-in consent before any scan, to the BIPA + Washington standard, for everyone. Minimize and ideally delete the raw image; never let face/health data near an ad or analytics SDK; never sell it. 18+ only. In-app delete + account deletion. Organization developer account. Real privacy policy + standalone biometric policy. Then have a lawyer check it before launch.

Primary sources informing this spec

FDA, General Wellness: Policy for Low-Risk Devices (Jan 2026) and FD&C; Act §201(g)/§520(o); FDA cosmetic-vs-drug guidance ('Is It a Cosmetic, a Drug, or Both?'); FTC Act §5, FTC Health Breach Notification Rule (amended, eff. July 29 2024) and related enforcement (GoodRx, BetterHelp, Premom, Flo); Illinois BIPA, 740 ILCS 14 (incl. 2024 amendment); Texas CUBI; Washington My Health My Data Act and RCW 19.375; state comprehensive privacy laws (CCPA/CPRA, VA, CO, CT, TX, OR, et al.); FTC COPPA Rule 2025 amendments; Apple App Store Review Guidelines (1.4.1, 5.1.1, 5.1.2, 5.1.3) and App Privacy / account-deletion requirements; GDPR Art. 9. Current to mid-2026; verify against the live texts and counsel before relying.